

TRYHACKME / WINDOWS ENUMERATION

ANTHEM

Penetration Test Recap

01. Reconnaissance	02. Web Enumeration	03. Credential Discovery
04. RDP Access (SG)	05. Hidden File Discovery	06. Privilege Escalation

MADE BY

Salah

ROOM STATUS — COMPLETE

Introduction

Anthem is a beginner-friendly Windows-based room on TryHackMe that focuses on web enumeration, OSINT-driven credential discovery, and Windows privilege escalation through file permission abuse. Unlike previous rooms (Blue, Ice, Blaster), Anthem requires no CVE exploitation — the entire attack chain relies on careful reading, source code analysis, and understanding Windows access controls.

Target IP	10.82.137.203
Operating System	Microsoft Windows (RDP-exposed)
Hostname	WIN-LU09299160F
Attacker IP	192.168.234.216 (Kali Linux)
Credentials (SG)	SG : UmbracolIsTheBest!
Credentials (Admin)	Administrator : ChangeMeBaby1MoreTime
CMS	Umbraco
Domain	anthem.com
Admin Identity	Solomon Grundy (SG@anthem.com)
Root Flag	THM{YOU_4R3_1337}

Phase 1 — Reconnaissance

Initial port scan to identify exposed services. Standard nmap with service version detection and default scripts.

```
$ nmap -sC -sV -oN anthem_nmap.txt 10.82.137.203
```

Port	Service	Significance
80/tcp	HTTP (IIS / Umbraco CMS)	Website to enumerate — primary attack surface
3389/tcp	RDP (ms-wbt-server)	Remote desktop — end-goal access vector

Two open ports immediately define the attack path: enumerate the web app to find credentials, then use RDP to log in. No exploit required.

Phase 2 — Web Enumeration

2.1 robots.txt — Password Discovery

robots.txt is a publicly accessible file that instructs web crawlers which paths to avoid. It is always one of the first files checked during web enumeration. In this case, a plaintext password had been left inside it.

```
# Navigate to:
http://10.82.137.203/robots.txt

# Result — password found in Disallow entries:
UmbracoIsTheBest!
```

2.2 CMS Identification

The password itself embedded the CMS name. Confirmed by navigating to the Umbraco admin login page.

```
# Login panel located at:
http://10.82.137.203/umbraco

# CMS identified: Umbraco (enterprise .NET CMS)
```

2.3 Administrator Identity via OSINT

The blog contained a post with a nursery rhyme attributed to James Orchard Halliwell. Googling the poem text revealed it was written about Solomon Grundy — a name matching the blog's admin account. The email SG@anthem.com confirmed the initials S.G. Email format was derived from the domain anthem.com discovered in page content and author profiles.

Admin Name	Solomon Grundy
Admin Email	SG@anthem.com
Domain	anthem.com
Password	UmbracoIsTheBest!

2.4 Hidden Flags in HTML Source

All four room flags were concealed in the website's HTML source — invisible on the rendered page. Found using Ctrl+U (View Source) and searching for THM{.

```
# Flag 1 — hidden in
THM{L0L_WH0_US3S_M3T4}

# Flag 2 — hidden in search input placeholder attribute
THM{G!T_G00D}

# Flag 3 — found on secondary page source
THM{L0L_WH0_D15}

# Flag 4 — found in author page source
THM{AN0TH3R_M3TA}
```

Phase 3 — Initial Access via RDP

Used the credentials discovered during web enumeration to authenticate over RDP on port 3389. Initial attempt with the full UPN format triggered Kerberos authentication failure — resolved by using the short username.

First Attempt (Failed):

```
# ERROR: Kerberos tried to resolve ANTHEM.COM domain controller - not found
$ xfreerdp /u:SG@anthem.com /p:UmbracoIsTheBest! /v:10.82.137.203 \
/cert:ignore /timeout:80000 /network:modem

# [ERROR] Cannot find KDC for realm 'ANTHEM.COM'
# [ERROR] ERRCONNECT_LOGON_FAILURE
```

Corrected Command (Successful):

```
# Removed domain from username - forces local/NTLM auth instead of Kerberos
$ xfreerdp /u:SG /p:UmbracoIsTheBest! /v:10.82.137.203 \
/cert:ignore /timeout:80000 /network:modem /f
```

Flag	Purpose
/u:SG	Short username — avoids Kerberos domain lookup
/p:	Password authentication
/v:	Target IP address
/cert:ignore	Skip TLS certificate validation (lab environment)
/timeout:80000	Extended timeout for VPN latency
/network:modem	Low-bandwidth mode — reduces disconnections
/f	Fullscreen mode

Phase 4 — Hidden File Discovery

After gaining desktop access as SG, Windows Explorer was configured to show hidden and system files. A non-standard folder was discovered at the root of C:\.

Enable Hidden Files:

```
# In Windows Explorer:
View → Options → View tab
✓ Show hidden files, folders and drives
✓ Uncheck: Hide protected operating system files
```

File Located:

Path	C:\backup\restore.txt
Size	21 bytes
Blocked	Access denied — Administrator-only permissions

Phase 5 — Privilege Escalation via File Ownership

restore.txt was locked to Administrator. However, Windows file ownership rules allow the owner to reassign permissions even without read access. By taking ownership of the file and granting SG full control, the contents were read without triggering a UAC prompt.

Steps Taken:

1. Right-click restore.txt → Properties → Security → Advanced
2. Owner shown as: SG (WIN-LU09299160F\SG) ← already owner
3. Click Add → type SG → Check Names → OK
4. Tick Full Control → Apply → OK
5. Open restore.txt in Notepad

```
# Contents of restore.txt:
ChangeMeBaby1MoreTime
```

Key insight: In Windows, an object's owner can always modify its DACL (Discretionary Access Control List), even if they have no other permissions. This is a well-known privilege escalation vector when sensitive files are owned by a compromised user account.

Phase 6 — Administrator Access & Root Flag

```
# Connect as Administrator:
$ xfreerdp /u:Administrator /p:ChangeMeBaby1MoreTime \
/v:10.82.137.203 /cert:ignore /timeout:80000 /network:modem /f

# Root flag found on Administrator's Desktop:
```

THM{YOU_4R3_1337}

Problems Faced & Solutions

Problem 1 — xfreerdp: Kerberos Authentication Failure

Problem	Login rejected with: Cannot find KDC for realm 'ANTHEM.COM' and ERRCONNECT_LOGON_FAILURE.
Cause	Using the UPN format SG@anthem.com caused xfreerdp to attempt Kerberos authentication, which requires a real domain controller — not present on a standalone TryHackMe box.
Diagnosed	Read the [ERROR] lines in the xfreerdp output — Kerberos and KDC were explicitly mentioned.
Fix	Removed the domain from the username. Used /u:SG instead of /u:SG@anthem.com, falling back to NTLM/local authentication.
Result	RDP session established successfully as SG.

Problem 2 — restore.txt: Permission Denied

Problem	Double-clicking restore.txt returned: You do not have permission to open this file.
Cause	The file's DACL had no entries permitting SG to read it — locked to Administrator only.
Diagnosed	Right-clicked → Properties → Security → Advanced revealed SG was the owner but had no permission entries.
Fix	As the file owner, SG could modify the DACL. Added SG with Full Control via the Advanced Security Settings dialog.
Result	File opened in Notepad revealing the Administrator password.

Problem 3 — Flags Not Visible on Page

Problem	Visiting blog pages showed no obvious flags in the rendered content.
Cause	Flags were embedded in HTML meta tags and form placeholder attributes — rendered invisibly by the browser.
Diagnosed	Used Ctrl+U to open page source, then Ctrl+F to search for THM{.
Fix	Systematic source code review of every page rather than relying on visual inspection alone.
Result	All four flags located in hidden HTML attributes.

Problem 4 — Admin Identity Not Obvious

Problem	The email JD@anthem.com appeared on a hiring post but did not match the admin name Solomon Grundy.
Cause	JD belonged to a different blog author (Jane Doe). The admin (Solomon Grundy / SG@anthem.com) was identified through a separate OSINT process.
Diagnosed	Googled the nursery rhyme poem found on the site — search results identified the subject as Solomon Grundy.
Fix	Distinguished between the post author (Jane Doe) and the site admin (Solomon Grundy). Used poem OSINT to confirm.
Result	Correct credentials SG@anthem.com / UmbracolIsTheBest! confirmed.

Tools & Technologies

Tool / Technology	Purpose	Notes
nmap	Port scanning & service detection	-sC -sV flags for scripts and version
xfreerdp	RDP client for remote desktop access	/cert:ignore /network:modem for stability
Umbraco CMS	CMS running the target website	Identified from robots.txt password
robots.txt	Web crawler instruction file	Contained plaintext password
Windows Explorer	File system navigation	Hidden files mode enabled
Notepad	Text file reading	Used to open restore.txt
Browser DevTools	HTML source analysis	Ctrl+U to view source, Ctrl+F to search
OSINT / Google	Poem attribution research	Identified Solomon Grundy from nursery rhyme
TryHackMe VPN	Network tunnel to target	OpenVPN tun0 interface
Kali Linux	Attack platform	All tools run from Kali terminal

Key Learnings

■ No exploit needed to compromise a machine	Anthem required zero CVE knowledge. Careful enumeration and reading discovered all credentials in plaintext. Many real-world breaches happen exactly this way.
■ robots.txt and HTML source are always worth checking	Sensitive data — passwords, API keys, internal paths — is regularly left in robots.txt or HTML comments/attributes by accident. Always Ctrl+U every page you visit.
■ OSINT is a legitimate attack technique	Googling a poem on a target's website revealed the administrator's identity. Open source intelligence is not a soft skill — it is a core part of every reconnaissance phase.
■ Username format affects authentication protocol	UPN format (user@domain.com) triggers Kerberos; short format (user) uses NTLM. Knowing the difference prevents wasted time on authentication failures.
■ Windows file ownership is a privilege escalation vector	An object's owner can always modify its DACL, even without read permissions. When a privileged file is owned by a compromised account, the attacker can grant themselves access — no admin required.
■ Hidden files on Windows are not truly hidden	C:\backup was invisible by default but trivially revealed with Show hidden files. Attackers always enable this setting during post-exploitation enumeration.

Engagement Summary

Objective	Result
Port Scanning	Ports 80 (HTTP) and 3389 (RDP) identified
CMS Identification	Umbraco — confirmed via robots.txt and /umbraco login page
Password Discovery	UmbracoIsTheBest! — found in robots.txt
Admin Identity	Solomon Grundy / SG@anthem.com — OSINT via poem research
Web Flags (x4)	All four THM flags found in HTML page source
Initial Access	RDP as SG — xfreerdp with short username format
Hidden File	C:\backup\restore.txt — revealed via hidden file mode
Privilege Escalation	File ownership abuse — DACL modified to grant SG read access
Admin Password	ChangeMeBaby1MoreTime — read from restore.txt
Full Admin Access	RDP as Administrator — full system control
Root Flag	THM{Y0U_4R3_1337}
Room Status	COMPLETE

Final Notes

Anthem stands apart from exploitation-heavy rooms by demonstrating that misconfigurations, careless credential storage, and poor access control decisions are often more dangerous than unpatched software vulnerabilities. The entire attack chain — from password discovery to Administrator access — relied on nothing more than methodical enumeration, reading carefully, and understanding how Windows manages file permissions.

These are skills that transfer directly to real-world engagements. Organisations regularly leave sensitive data in publicly accessible files, embed credentials in HTML, and misconfigure access controls on critical files. The habit of checking robots.txt, reading page source, and enumerating the filesystem thoroughly will surface findings that automated scanners miss entirely.

TryHackMe — Anthem Room · Completed by Salah · Room Status: COMPLETE